

INTERNAL AUDIT PLAN - CYCLE 1

Organization: VertexOne Digital Services

Document Type: Internal Audit Plan

Audit Programme: Cycle 1

Standard: ISO/IEC 27001:2022

Reference: Clause 9.2 - Internal Audit

Status: Approved for Execution

Prepared By: Junior GRC Analyst

Lead Auditor: GRC Manager

1. Audit Purpose

The purpose of Cycle 1 is to assess the conformity and operating effectiveness of selected information security controls within the VertexOne Digital Services ISMS.

The audit will evaluate whether the selected controls are appropriately implemented, operating as intended, supported by objective evidence, and aligned with the organization's documented requirements and risk treatment decisions.

2. Audit Scope

Cycle 1 will cover the following information security control areas:

Control Area	ISO/IEC 27001:2022 Annex A Controls
Access Management	A.8.2 — Privileged Access Rights; A.8.5 — Secure Authentication
Endpoint Protection	A.8.1 — User Endpoint Devices; A.8.7 — Protection Against Malware
Security Awareness	A.6.3 — Information Security Awareness, Education and Training
Vulnerability Management	A.8.8 — Management of Technical Vulnerabilities
Backup	A.8.13 — Information Backup
Supplier Security	A.5.19 — Information Security in Supplier Relationships

The audit will assess both documented requirements and evidence demonstrating operational implementation of the selected controls.

3. Audit Objectives

The Cycle 1 audit objectives are to:

1. Verify that selected controls conform to applicable ISMS requirements.
2. Determine whether controls have been implemented as documented.
3. Assess whether controls are operating effectively.
4. Verify the availability and adequacy of supporting audit evidence.
5. Identify control weaknesses, nonconformities, and improvement opportunities.
6. Recommend appropriate corrective actions for identified findings.

4. Audit Criteria

The audit will use the following criteria:

- ISO/IEC 27001:2022 requirements.
- VertexOne Information Security Policy.
- Statement of Applicability (SoA).
- Operational Control Register.
- Applicable security procedures and standards.
- Risk Register and associated risk treatment decisions.
- Control implementation requirements.
- Relevant audit evidence and operational records.

5. Audit Schedule

Day	Activity	Key Evidence / Output
Day 1	Document review: Statement of Applicability, Operational Control Register, and Audit Evidence Register	Document review notes and identified evidence gaps
Day 2	Technical validation: MFA configuration, EDR coverage, and backup restoration records	Technical validation evidence
Day 3	Personnel interviews with CISO, IT Operations, HR, and Engineering Lead	Interview notes and control-owner confirmations
Day 4	Sampling: privileged access reviews, supplier/vendor questionnaires, and security training completions	Sample results and supporting evidence
Day 5	Findings consolidation and draft report preparation	Draft Internal Audit Report

6. Audit Methods

The audit will use a combination of:

- **Document Review** — examination of policies, procedures, registers, and documented requirements.
- **Evidence Review** — assessment of records demonstrating control operation.
- **Technical Validation** — verification of selected technical configurations and operational records.
- **Interviews** — discussions with relevant control owners and responsible personnel.
- **Sampling** — examination of representative records to determine whether controls are consistently operating.
- **Observation** — where appropriate, direct observation of control activities or processes.

Audit conclusions will be based on objective evidence obtained during the audit.

7. Auditor and Independence

Lead Auditor: GRC Manager

The GRC Manager will lead the audit and coordinate audit activities.

Where the GRC Manager has personally implemented or operates a control under review, an independent review will be performed by the **CISO or another appropriately competent reviewer** to preserve audit objectivity and independence.

No auditor should assess their own work or approve findings relating to controls they directly operate.

8. Audit Evidence

Evidence may include, but is not limited to:

- MFA configuration records.
- Endpoint/EDR coverage reports.
- Privileged access review records.
- User access review evidence.
- Backup configuration and restoration test records.
- Vulnerability scan and remediation records.
- Security awareness and training completion records.
- Supplier security assessments and questionnaires.
- Relevant policies, procedures, and control documentation.
- Risk and control registers.

Evidence will be recorded in the organization's **Audit Evidence Register** and referenced against the applicable audit criteria and control.

9. Findings Classification

Audit findings will be classified based on their significance and impact.

Classification	Description
Nonconformity — Major	A significant failure or systemic weakness that materially affects the ability of the ISMS or control to achieve its intended outcome.
Nonconformity — Minor	A limited failure to meet an applicable requirement that does not indicate a significant systemic breakdown.
Observation	A condition that does not currently constitute a nonconformity but warrants management attention.
Opportunity for Improvement	A practical improvement that may strengthen the effectiveness or efficiency of an existing process or control.

10. Audit Deliverable

The primary deliverable will be an **Internal Audit Report** containing:

- Audit scope and objectives.
- Audit criteria and methodology.
- Controls and processes reviewed.
- Evidence examined.
- Summary of audit results.
- Classified findings.
- Supporting evidence and observations.
- Recommended corrective actions.
- Responsible control/process owners.
- Target completion dates.
- Follow-up requirements.

The final report will be submitted to relevant management for review and corrective-action planning.

11. Approval

Role	Responsibility	Status
Prepared By	Junior GRC Analyst	Prepared
Lead Auditor	GRC Manager	Assigned
Independent Reviewer	CISO	Assigned where required
Approval Status	Approved for execution	Approved

Document Status: Approved for Execution